FORCE N
sa ëllëg ci xarala

Mentorat CYBERSÉCURITÉ CYB6 / Groupe 3

Encadrant : M. Ibrahima Samba DIOP
Consultant en Cybersécurité

Rapport de Lab

Défense contre la DHCP Starvation
DHCP Snooping et Port-Security

(démonstration sous Cisco Packet Tracer)

Étudiant(e) : HAMADY CISSE

Date : 23 octobre 2026

Environnement : Cisco Packet Tracer, réseau `192.168.6.0/24`

Document réalisé dans un cadre strictement pédagogique et sur une maquette simulée isolée.

Table des matières

1 Introduction **2**
1.1 Objectifs . . . 2

2 Environnement du laboratoire **2**

3 Tâche 1 : Maquette et serveur DHCP fonctionnel (état de référence) **3**
3.1 Rappels théoriques . . . 3
3.2 Manipulations . . . 4
3.3 Questions de la tâche 1 . . . 6

4 Tâche 2 : Mise en place des contre-mesures sur le switch **7**
4.1 Rappels théoriques . . . 7
4.2 Manipulations . . . 7
4.3 Questions de la tâche 2 . . . 9

5 Tâche 3 : Validation de la défense (usurpation de MAC neutralisée) **9**
5.1 Manipulations . . . 9
5.2 Questions de la tâche 3 . . . 12

6 Réflexion globale et conclusion **13**

7 Annexe : commandes utilisées, rôles et options **13**

1. Introduction

Les deux premiers rapports de ce lab ont mené l'attaque **DHCP Starvation** jusqu'à son terme : épuisement du pool sur un serveur VyOS/Kea (version VirtualBox), puis sur un véritable routeur Cisco (version GNS3). Les deux concluaient sur la même parade : il faut durcir la **couche d'accès**, c'est-à-dire le switch, avec le **DHCP snooping** et la **port-security**. Ce troisième volet passe de la théorie à la pratique et **montre** cette défense en action.

Les outils d'attaque (yersinia, Scapy) ne tournent pas dans Packet Tracer. On ne rejoue donc pas le flood ici. En revanche, Packet Tracer simule des switches Cisco complets, ce qui permet de configurer les contre-mesures et de reproduire le mécanisme décisif de l'attaque : l'**usurpation d'adresse MAC**. L'objectif est de prouver, captures à l'appui, qu'une MAC usurpée est bloquée net par le switch.

Avertissement légal et éthique

Toutes les manipulations décrites ont été réalisées sur une **maquette simulée** sous Cisco Packet Tracer, sans aucun lien avec un réseau réel ni avec Internet. Les techniques de durcissement présentées ici sont défensives. L'usurpation de MAC n'est montrée que pour valider la contre-mesure, sur du matériel simulé appartenant au contexte pédagogique. N'appliquez jamais ce type de test sur un réseau sans autorisation écrite du propriétaire.

1.1 Objectifs

— Monter sous Packet Tracer une maquette représentative : un routeur serveur DHCP, un switch d'accès administrable, un poste légitime et un poste attaquant.

— Vérifier le fonctionnement normal du DHCP (les postes reçoivent une adresse).

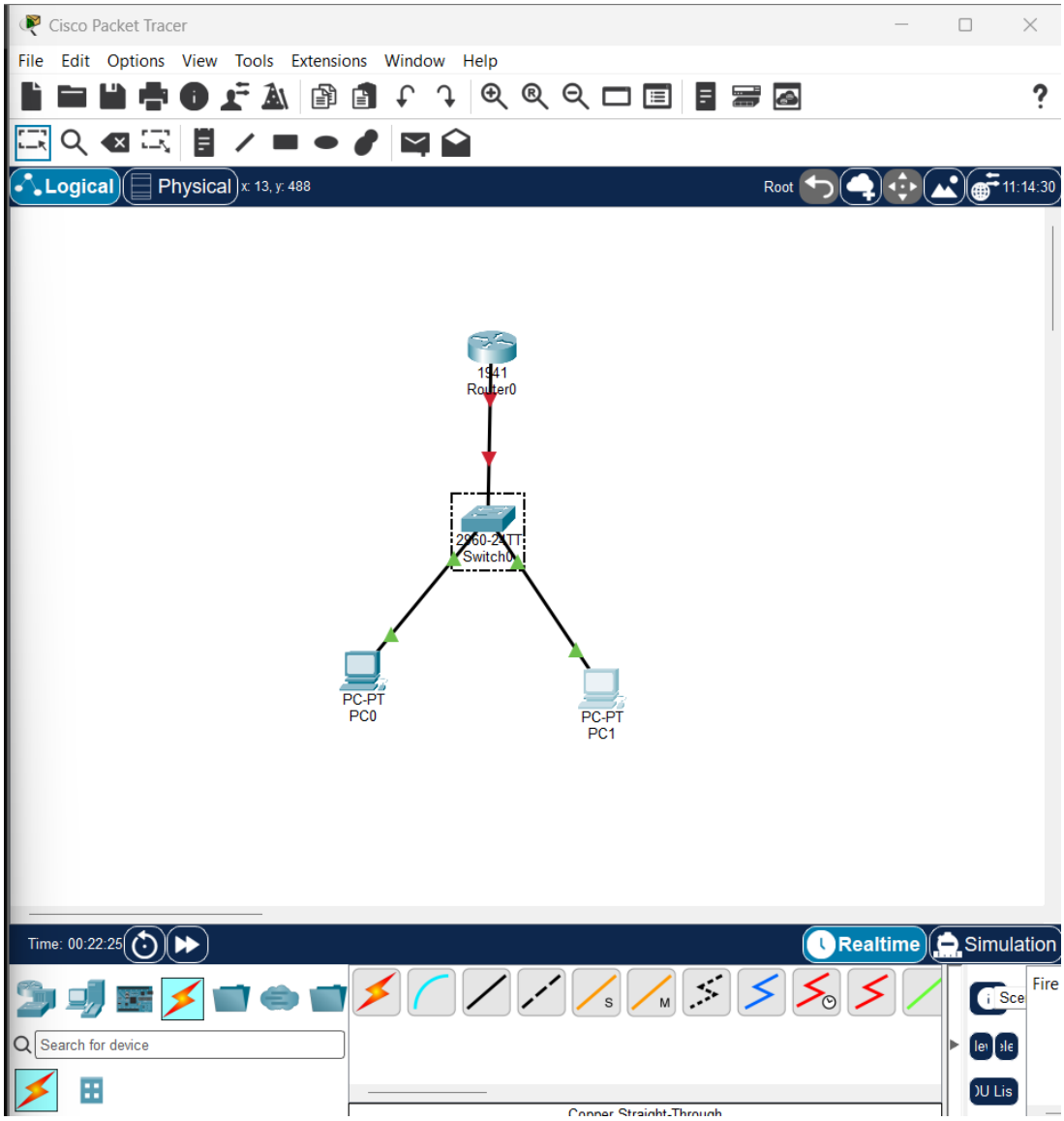
— Configurer les contre-mesures sur le switch : **DHCP snooping** (port de confiance et limite de débit) et **port-security** (une seule MAC par port, coupure en cas de violation).

— Simuler l'usurpation de MAC, cœur de la DHCP Starvation, et prouver que le port bascule en `err-disabled`, ce qui neutralise l'attaque.

2. Environnement du laboratoire

La maquette est volontairement minimale, mais contient l'élément qui manquait aux deux montages précédents : un **switch administrable** (Cisco 2960), seul équipement capable de porter le DHCP snooping et la port-security. Le serveur DHCP est un routeur Cisco 1941, et deux PC jouent le client légitime et l'attaquant.

Équipement	Rôle	Adresse IP	Raccordement
R1 (Cisco 1941)	Serveur DHCP / passerelle	`192.168.6.1`	`Gig0/0` → switch `Fa0/1`
Switch0 (2960)	Switch d'accès (défense)	`--`	port `Fa0/1` de confiance
PC0	Client légitime	`192.168.6.2` (DHCP)	`Fa0/2`
PC1	Attaquant	`192.168.6.3` (DHCP)	`Fa0/3`



Maquette Packet Tracer : `R1 (1941)` → `Switch0 (2960)` → `PC0` (légitime) et `PC1` (attaquant). Tous les liens sont actifs (verts) : c'est l'état sain, avant toute attaque.

Le choix des ports n'est pas anodin. `Fa0/1` relie le switch au **vrai** serveur DHCP : ce sera le port *de confiance*. `Fa0/2` et `Fa0/3` relient des postes utilisateurs : ce sont des ports *non approuvés*, ceux par lesquels une attaque arriverait.

3. Tâche 1 : Maquette et serveur DHCP fonctionnel (état de référence)

Avant de défendre quoi que ce soit, il faut un réseau qui marche. On configure le routeur en serveur DHCP et on vérifie que les deux postes reçoivent bien une adresse. C'est la photo « avant » à laquelle on comparera le comportement sous défense.

3.1 Rappels théoriques

Le DHCP distribue automatiquement les adresses IP via l'échange **DORA** (DISCOVER, OFFER, REQUEST, ACK). Le serveur identifie chaque client par son **adresse MAC** et lui réserve une adresse du pool. C'est précisément cette association « une MAC = une adresse » que l'attaque DHCP Starvation détourne, en inondant le serveur de MAC falsifiées jusqu'à vider le pool.

3.2 Manipulations

1. Configurer le routeur R1 en serveur DHCP :

```
enable
configure terminal
 hostname R1
 interface GigabitEthernet0/0
  ip address 192.168.6.1 255.255.255.0
  no shutdown
 exit
 ip dhcp excluded-address 192.168.6.1
 ip dhcp pool L3SIMAC
  network 192.168.6.0 255.255.255.0
  default-router 192.168.6.1
 exit
end
write memory
```

```
Router>enable
Router#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Router(config)#hostname R1
R1(config)#interface GigabitEthernet0/0
R1(config-if)#ip address 192.168.6.1 255.255.255.0
R1(config-if)#no shutdown

R1(config-if)#
%LINK-5-CHANGED: Interface GigabitEthernet0/0, changed state to up

%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/0, changed state to up
exit
R1(config)#ip dhcp pool L3SIMAC
R1(dhcp-config)#network 192.168.6.0 255.255.255.0
R1(dhcp-config)#default-router 192.168.6.1
R1(dhcp-config)#exit
R1(config)#end
R1#
%SYS-5-CONFIG_I: Configured from console by console

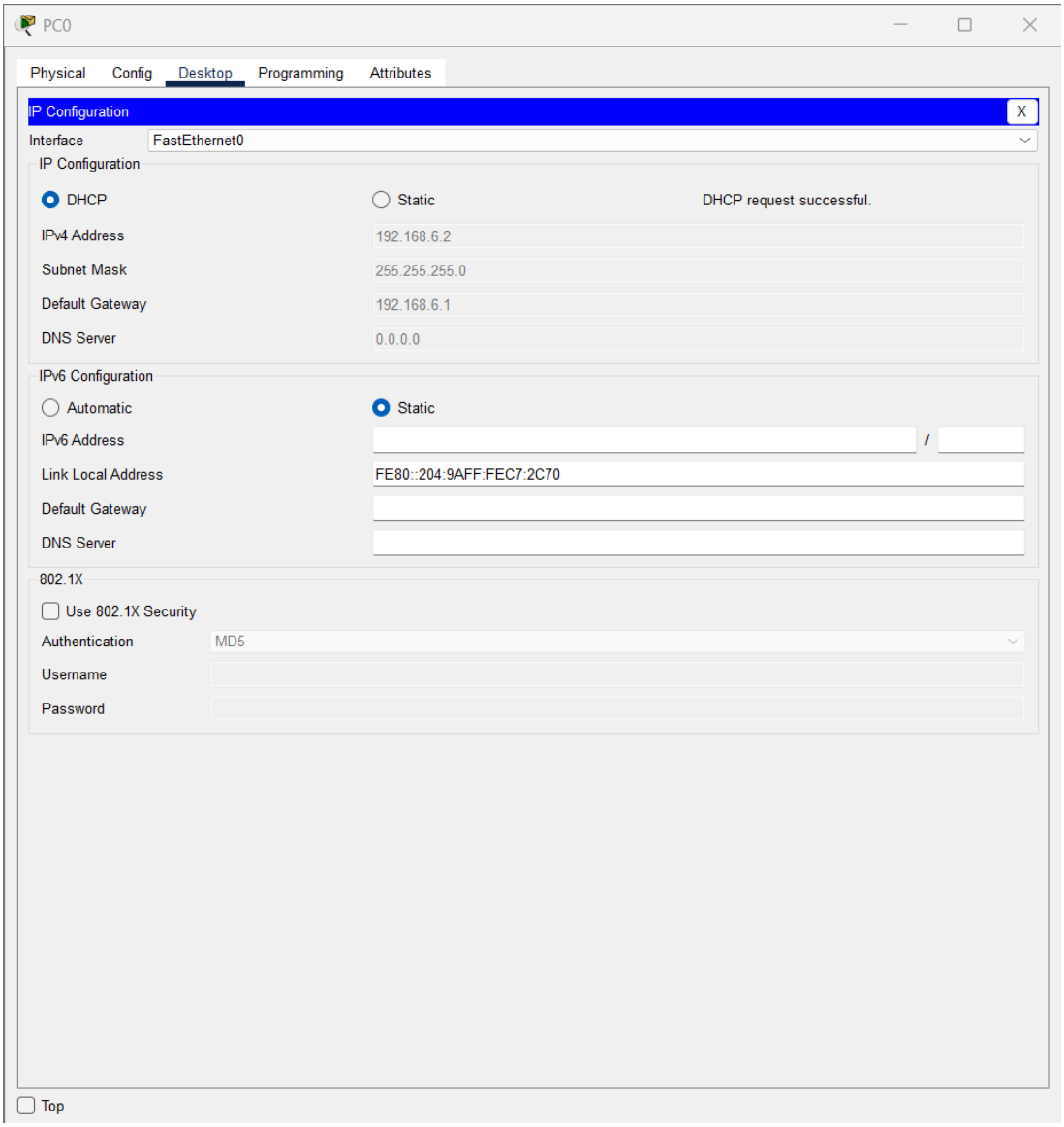
R1#show ip interface brief
Interface              IP-Address      OK? Method Status                Protocol
GigabitEthernet0/0     192.168.6.1     YES manual up                    up
GigabitEthernet0/1     unassigned      YES unset  administratively down down
Vlan1                  unassigned      YES unset  administratively down down
R1#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
R1(config)#ip dhcp excluded-address 192.168.6.1
R1(config)#end
R1#
%SYS-5-CONFIG_I: Configured from console by console

R1#write memory
Building configuration...
[OK]
R1#show ip interface brief
Interface              IP-Address      OK? Method Status                Protocol
GigabitEthernet0/0     192.168.6.1     YES manual up                    up
GigabitEthernet0/1     unassigned      YES unset  administratively down down
Vlan1                  unassigned      YES unset  administratively down down
R1#
```

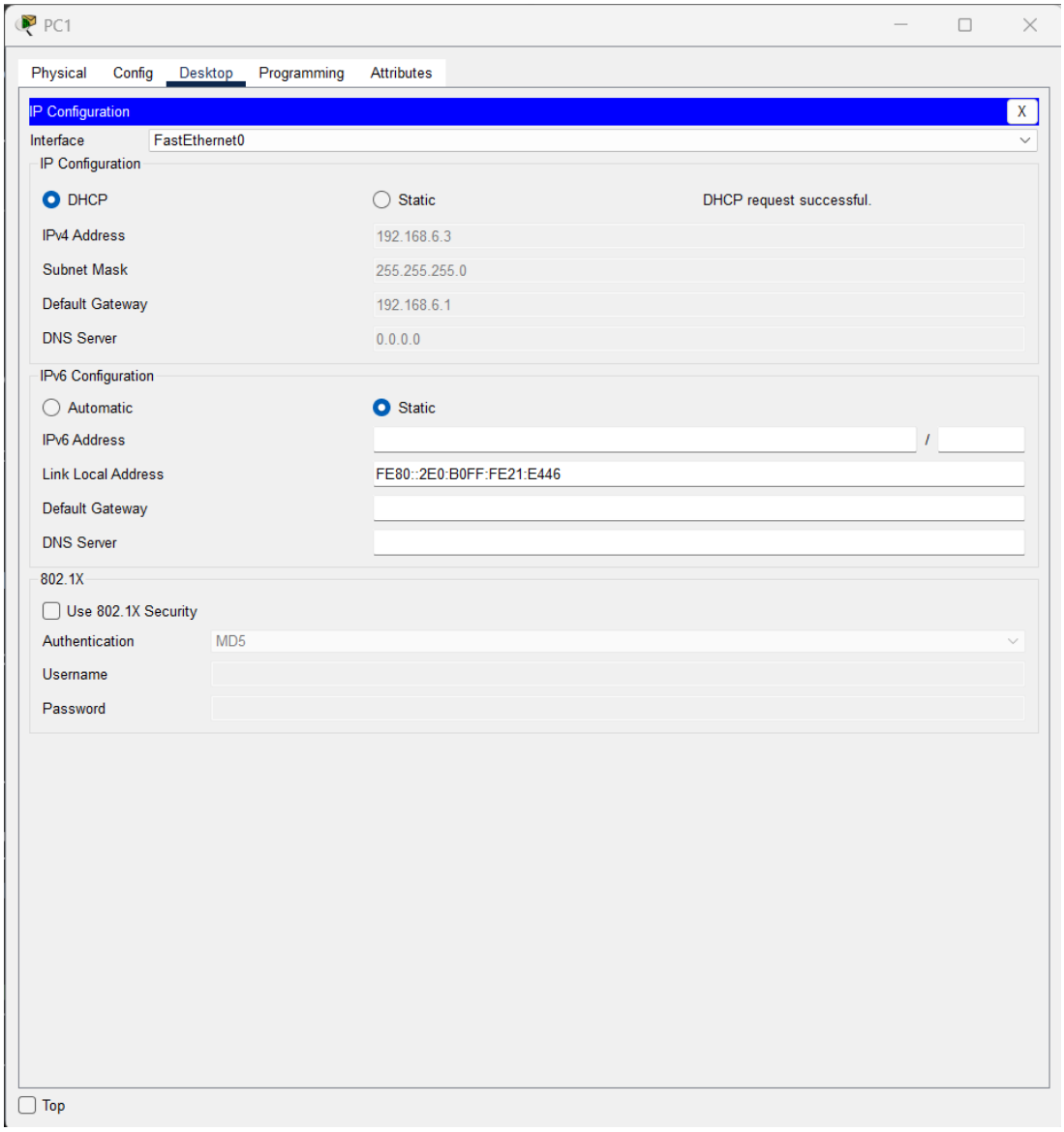
Copy Paste

Configuration de R1 : `GigabitEthernet0/0` en `192.168.6.1`, pool `L3SIMAC`, passerelle exclue du pool. `show ip interface brief` confirme l'interface `up/up`.

2. Mettre les deux PC en DHCP et vérifier l'adresse obtenue : sur chaque poste, *Desktop → IP Configuration → DHCP.*



PC0 (client légitime) a reçu `192.168.6.2`*, masque* `/24`*, passerelle* `192.168.6.1`*. Mention* DHCP request successful.



PC1 (poste qui servira d'attaquant) a reçu `192.168.6.3` du même serveur. Le DHCP fonctionne normalement pour les deux postes.

3. Confirmer les baux côté serveur :

```
show ip dhcp binding
```

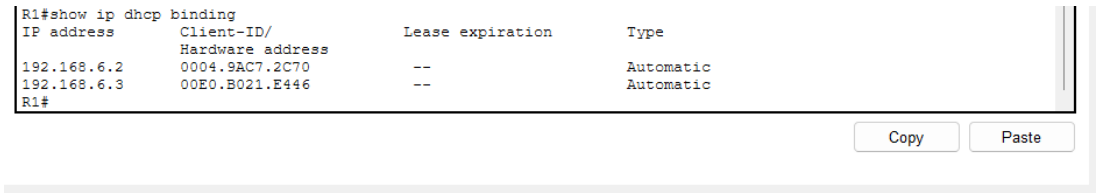


Table des baux de R1 : `192.168.6.2` et `192.168.6.3`, de type Automatic*, associées aux MAC réelles des deux PC. État de référence établi.*

3.3 Questions de la tâche 1

Q1. Pourquoi le serveur attribue-t-il une adresse différente à chaque PC ?

Réponse : Parce qu'il distingue les clients par leur adresse MAC. Chaque PC présente une MAC unique, le serveur lui réserve donc une entrée distincte dans sa table. C'est le comportement

normal, mais c'est aussi la faille exploitée par la starvation : si un attaquant présente des centaines de fausses MAC, le serveur croit voir des centaines de clients et épuise son pool.

4. Tâche 2 : Mise en place des contre-mesures sur le switch

On arme maintenant le switch. Deux mécanismes se complètent : le DHCP snooping encadre le trafic DHCP, la port-security limite le nombre d'adresses MAC par port.

4.1 Rappels théoriques

DHCP snooping. Le switch classe ses ports en *trust* et *untrusted*. Seul un port de confiance (celui qui mène au vrai serveur) a le droit d'émettre des réponses DHCP (OFFER, ACK). Cela bloque d'emblée les faux serveurs DHCP. Sur les ports non approuvés, on ajoute une **limite de débit** DHCP : un flux anormal de requêtes y est étranglé.

Port-security. Le switch mémorise les adresses MAC vues sur chaque port d'accès et limite leur nombre. Avec un maximum de **1 MAC** et une action **shutdown**, dès qu'une deuxième MAC apparaît sur le port, celui-ci est coupé (`err-disabled`). C'est la réponse directe à l'usurpation de MAC : l'attaque change de MAC à chaque paquet, la port-security la stoppe au deuxième.

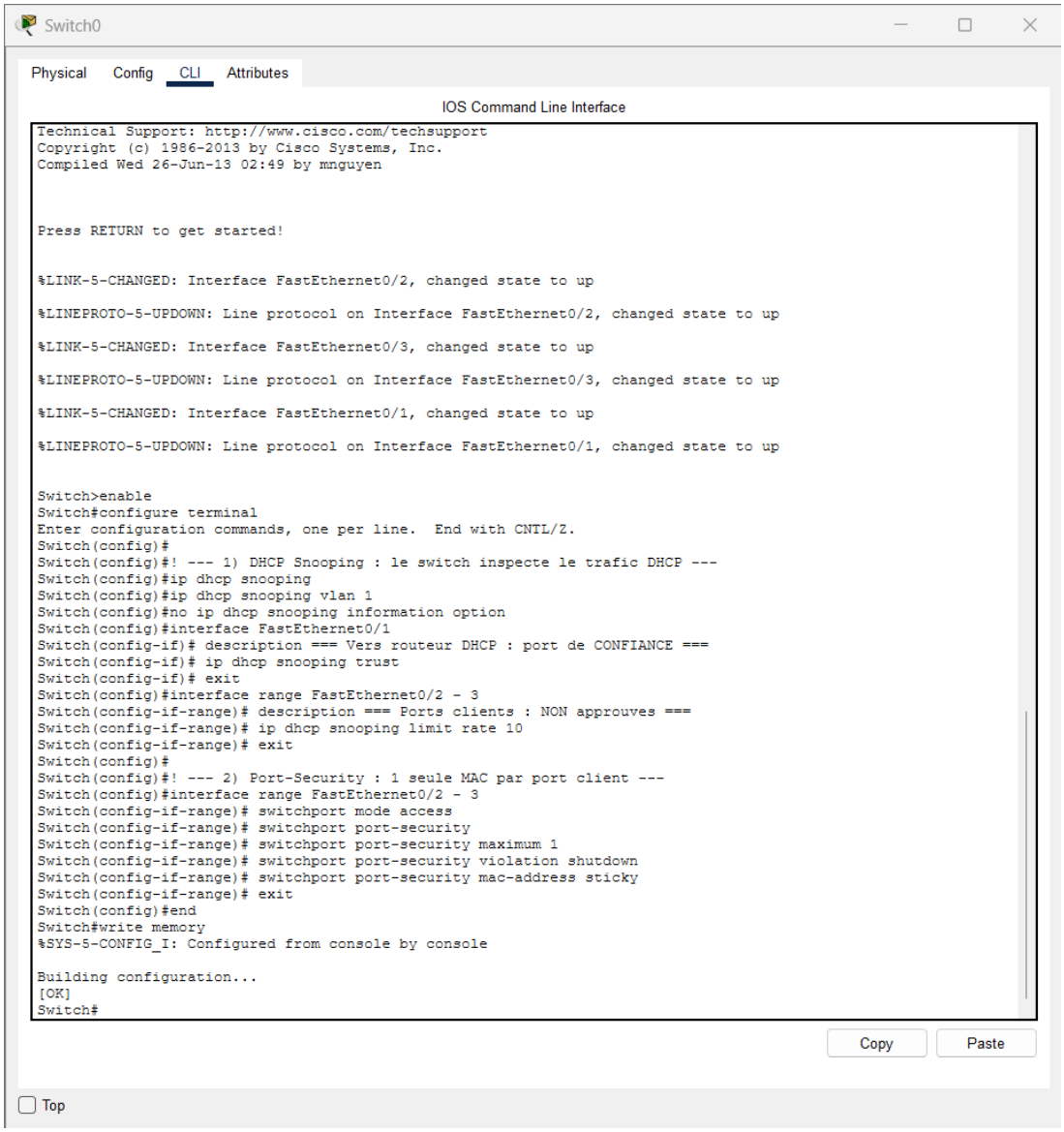
4.2 Manipulations

1. Activer le DHCP snooping et désigner le port de confiance :

```
enable
configure terminal
 ip dhcp snooping
 ip dhcp snooping vlan 1
 no ip dhcp snooping information option
 interface FastEthernet0/1
  ip dhcp snooping trust
 exit
 interface range FastEthernet0/2 - 3
  ip dhcp snooping limit rate 10
 exit
```

2. Activer la port-security sur les ports clients :

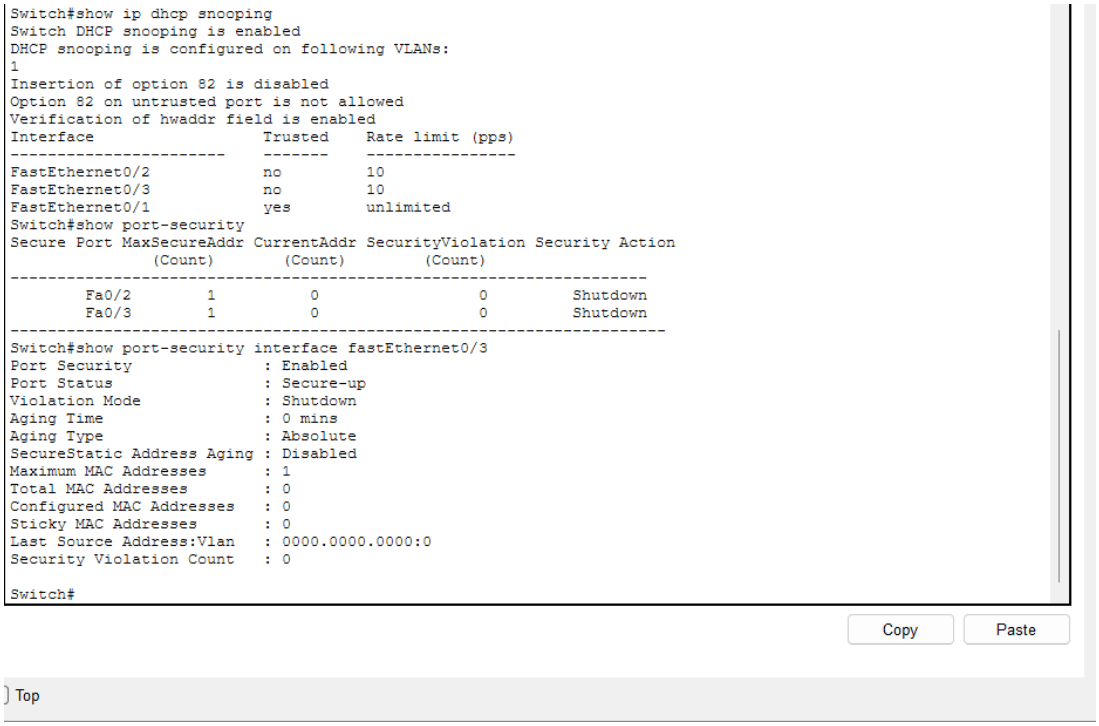
```
 interface range FastEthernet0/2 - 3
  switchport mode access
  switchport port-security
  switchport port-security maximum 1
  switchport port-security violation shutdown
  switchport port-security mac-address sticky
 exit
end
write memory
```



Configuration de la défense sur Switch0 : DHCP snooping (VLAN 1, `Fa0/1` en trust*, limite de débit sur les ports clients) puis port-security (max 1 MAC, violation* shutdown*, apprentissage* sticky*).*

3. Vérifier que les contre-mesures sont en place :

```
show ip dhcp snooping
show port-security
show port-security interface fastEthernet0/3
```



Vérifications : le DHCP snooping est actif sur le VLAN 1, `Fa0/1` *est* Trusted = yes *(le routeur),* `Fa0/2` *et* `Fa0/3` *sont non approuvés avec une limite de* `10 pps`*. La port-security affiche* Maximum = 1 *et l'action* Shutdown *sur les ports clients.*

4.3 Questions de la tâche 2

Q1. Pourquoi seul le port `Fa0/1` est-il déclaré *trust* ?

Réponse : Parce que c'est le seul port derrière lequel se trouve un serveur DHCP légitime (le routeur R1). Un port de confiance est autorisé à transmettre les réponses DHCP. Si on laissait les ports clients en confiance, n'importe quel poste pourrait se faire passer pour un serveur DHCP et distribuer de fausses passerelles. En gardant `Fa0/2` et `Fa0/3` non approuvés, toute réponse DHCP venant d'un poste est ignorée, et le débit de requêtes y est plafonné.

Q2. En quoi `maximum 1` contre-t-il directement la starvation ?

Réponse : La starvation repose sur l'envoi de nombreuses requêtes avec une MAC source différente à chaque fois. Avec un maximum d'une seule MAC autorisée par port, la première MAC est apprise, et la deuxième MAC falsifiée déclenche aussitôt la violation. Le port se coupe avant que le flood n'ait pu vider le pool. La valeur *sticky* fait que la MAC légitime est mémorisée automatiquement, sans avoir à la saisir à la main.

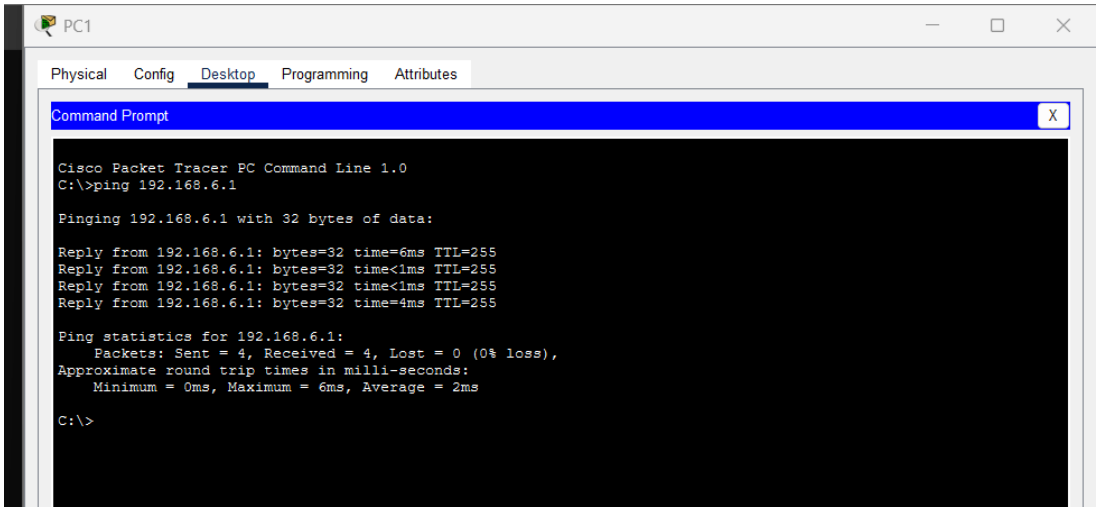
5. Tâche 3 : Validation de la défense (usurpation de MAC neutralisée)

Place à la preuve. On simule le geste central de l'attaque, l'usurpation de MAC, et on observe la réaction du switch.

5.1 Manipulations

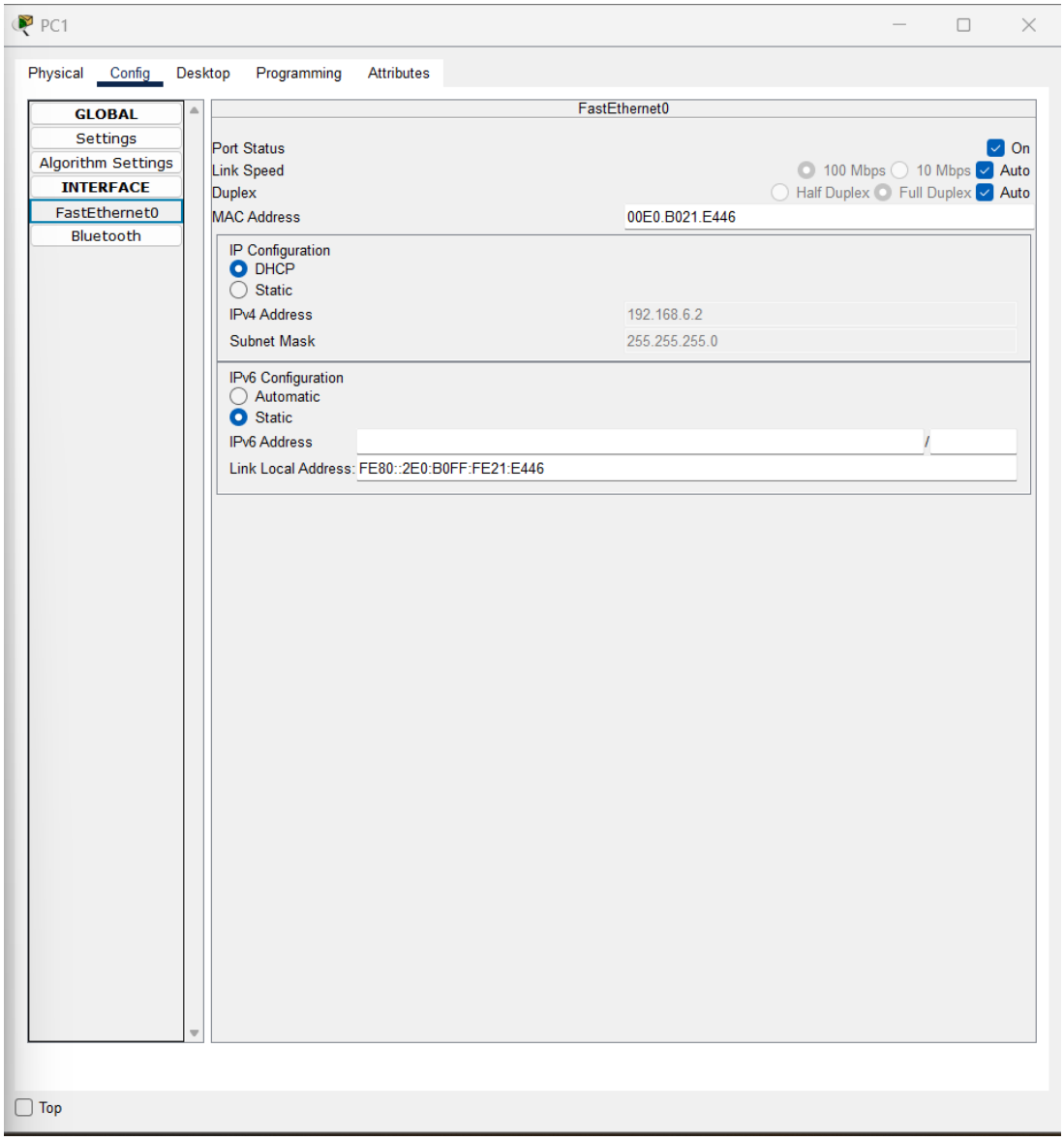
1. Trafic normal avec la MAC légitime : depuis PC1, on envoie d'abord un `ping` vers la passerelle. Sa vraie MAC est ainsi apprise comme l'unique MAC autorisée du port.

```
ping 192.168.6.1
```



PC1 avec sa MAC d'origine : le `ping` vers `192.168.6.1` répond (4 sur 4). Le port `Fa0/3` a mémorisé cette MAC comme adresse sécurisée sticky.

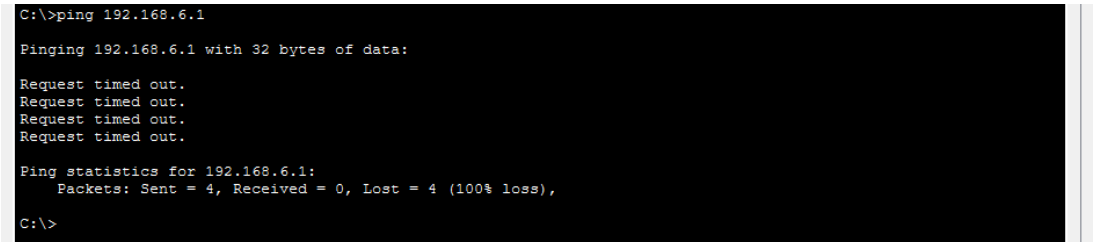
2. Usurper une adresse MAC : dans l'onglet *Config* de PC1, interface `FastEthernet0`, on remplace la MAC par une valeur falsifiée (`00AA.BBCC.DDEE`). C'est exactement ce que fait un outil de starvation à chaque paquet.



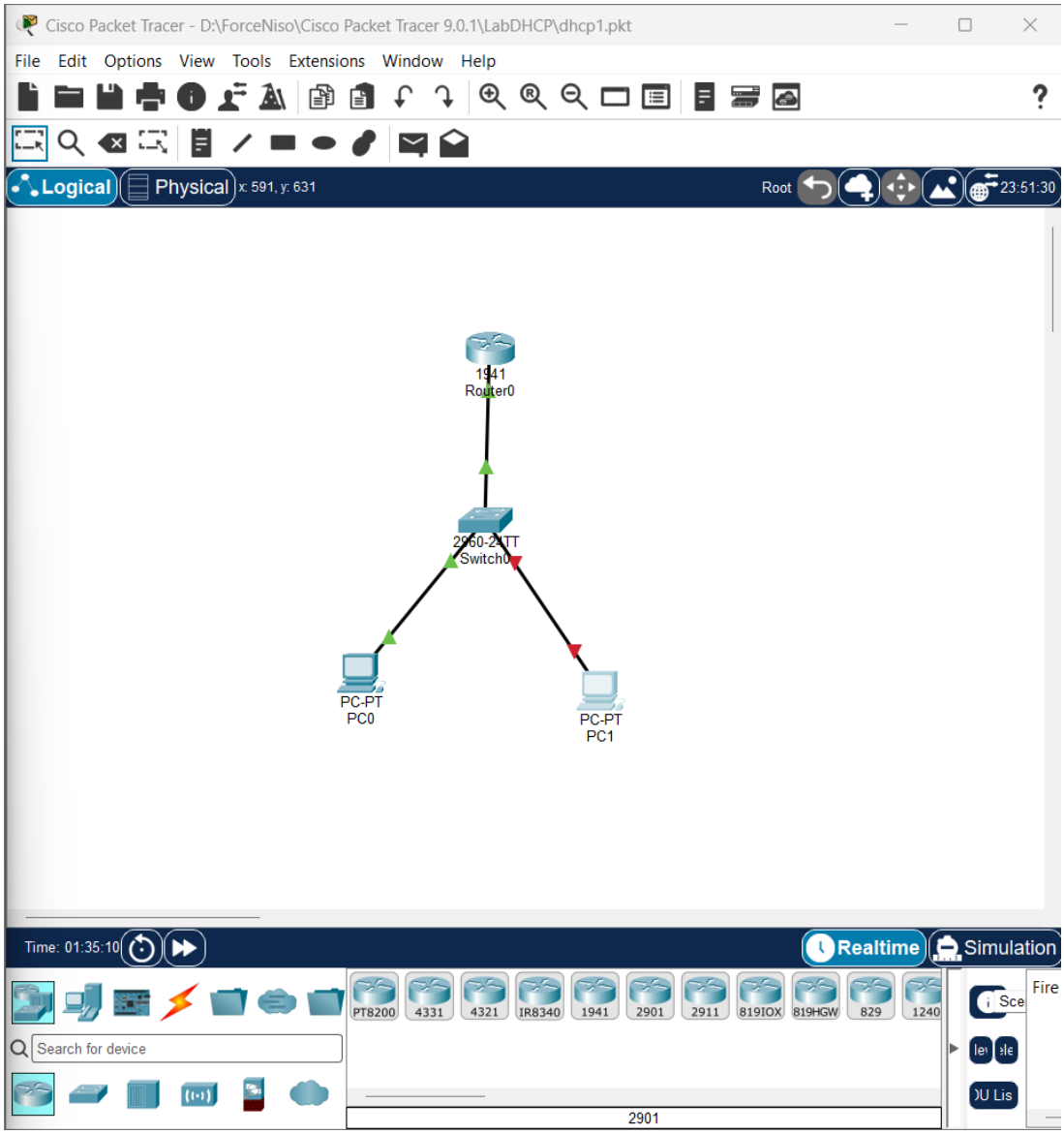
Onglet Config *de PC1 : le champ* MAC Address *permet de falsifier l'adresse matérielle du poste (ici la MAC d'origine* `00E0.B021.E446`*, avant usurpation).*

3. Renvoyer du trafic avec la MAC usurpée :

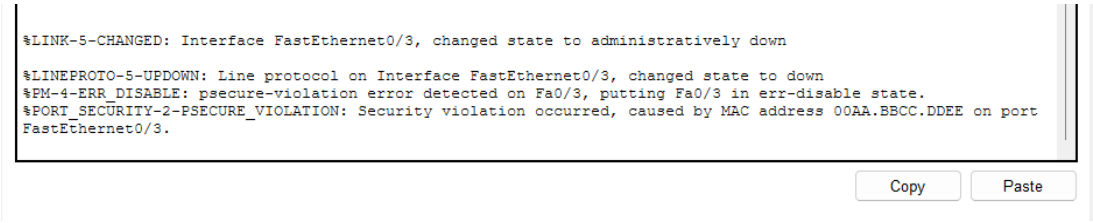
```
ping 192.168.6.1
```



Après usurpation, le même `ping` *échoue (100 % de perte). Le poste attaquant est coupé du réseau.*



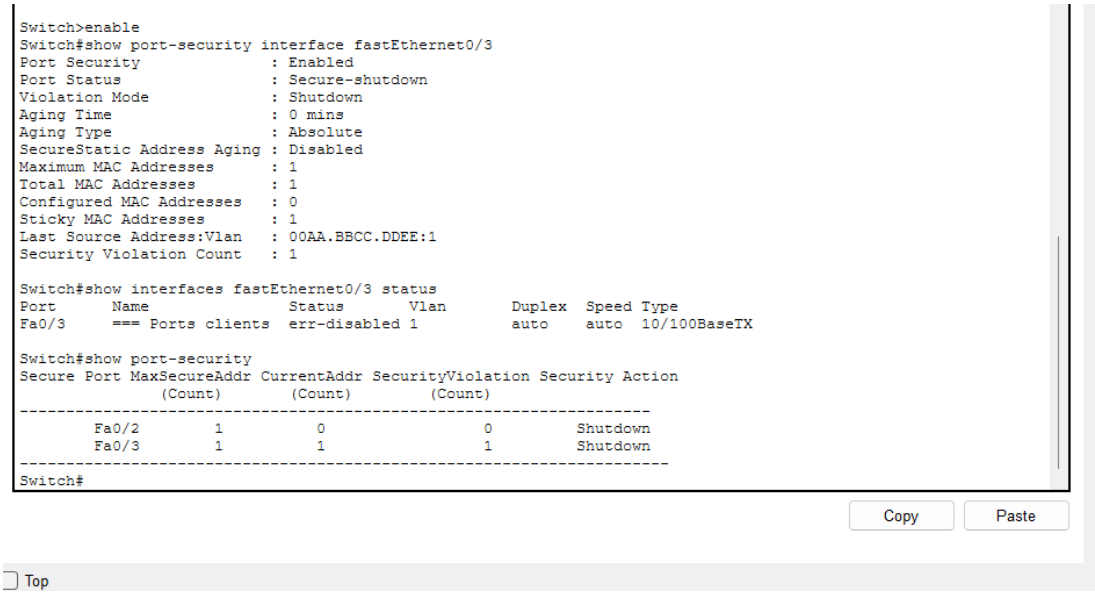
Vue de la maquette : le lien entre `PC1` *et* `Switch0` *est passé au* **rouge**. *Le port a été désactivé, les autres liens restent actifs.*



Journaux du switch au moment de l'attaque : `%PM-4-ERR_DISABLE: psecure-violation ... putting Fa0/3 in err-disable state` et `%PORT_SECURITY-2-PSECURE_VIOLATION: ... caused by MAC address 00AA.BBCC.DDEE on port Fa0/3`. La MAC usurpée est nommée explicitement.

4. Constater l'état verrouillé du port :

```
show port-security interface fastEthernet0/3
show interfaces fastEthernet0/3 status
show port-security
```



Preuve chiffrée : `Port Status = Secure-shutdown`, `Last Source Address = 00AA.BBCC.DDEE`, `Security Violation Count = 1`. Le port `Fa0/3` est en `err-disabled`. L'usurpation de MAC a été détectée et bloquée.

5.2 Questions de la tâche 3

Q1. Que se serait-il passé sans la port-security ?

Réponse : Rien n'aurait arrêté la MAC falsifiée. Le switch l'aurait relayée vers le routeur, qui aurait réservé une nouvelle adresse pour cette fausse identité. Répété des centaines de fois, ce geste vide le pool : c'est la starvation observée dans les deux rapports précédents. La port-security casse la chaîne dès la deuxième MAC.

Q2. Le port est en `err-disabled`. Comment le remettre en service après l'incident ?

Réponse : Un port en `err-disabled` ne se réactive pas tout seul (sauf si on a configuré un *errdisable recovery*). L'administrateur doit traiter la cause, puis relancer le port à la main :

```
interface fastEthernet0/3
 shutdown
 no shutdown
```

Cette intervention manuelle est voulue : elle force un humain à constater qu'une attaque a eu lieu avant de rouvrir l'accès.

6. Réflexion globale et conclusion

1. **Deux défenses complémentaires.** Le DHCP snooping agit sur le *trafic DHCP* (qui a le droit de répondre, à quel débit) ; la port-security agit sur les *adresses MAC* (combien par port). Prises ensemble, elles couvrent à la fois le faux serveur DHCP et l'épuisement de pool par usurpation.
2. **La port-security est la parade décisive contre la starvation.** L'attaque vit de l'usurpation de MAC ; limiter le nombre de MAC par port la tue à la source. La démonstration le montre sans ambiguïté : une seule MAC falsifiée suffit à faire tomber le port en `err-disabled`.
3. **Limite de l'exercice.** Packet Tracer ne lance pas de vrai flood. On n'a donc pas rejoué l'attaque complète ici, mais reproduit son mécanisme central (l'usurpation de MAC) et prouvé qu'il est bloqué. Les deux rapports précédents couvrent, eux, l'attaque réelle jusqu'à l'épuisement du pool.

Conclusion. Ce troisième volet referme le lab en passant du côté défense. Le même réseau qui distribuait tranquillement ses adresses se transforme, une fois le switch durci, en piège pour l'attaquant : la MAC usurpée est repérée et le port se verrouille instantanément. La leçon des trois rapports converge : le DHCP n'authentifie pas ses clients, c'est donc au switch d'accès de poser la limite, par le DHCP snooping et la port-security.

HAMADY CISSE
Diplômé en Cryptographie et Sécurité de l'Information
`Courriel : hamadycisse7540@gmail.com  GitHub : hamadycisse7540-hash`
`Empreinte GPG : A6F4 0DFD EE3E B7AE 80B3 6E77 361C 9E02 B790 303E`
Document signé numériquement (GPG). Vérifiez son authenticité et son intégrité avec la clé publique ci-dessus.

7. Annexe : commandes utilisées, rôles et options

Commande	Rôle et options
Serveur DHCP (routeur Cisco IOS)	
`enable`	Passe en mode privilégié (EXEC).
`configure terminal`	Entre en configuration globale.
`interface GigabitEthernet0/0`	Sélectionne l'interface du serveur.
`ip address 192.168.6.1 255.255.255.0`	Affecte l'IP et le masque /24 (la passerelle).
`no shutdown`	Active l'interface.
`ip dhcp excluded-address 192.168.6.1`	Retire la passerelle du pool distribuable.
`ip dhcp pool L3SIMAC`	Crée le pool DHCP `L3SIMAC`.
`network 192.168.6.0 255.255.255.0`	Plage distribuable du pool.
`default-router 192.168.6.1`	Passerelle annoncée aux clients.
`show ip dhcp binding`	Liste les baux attribués (état de référence).
DHCP snooping (switch)	
`ip dhcp snooping`	Active globalement le DHCP snooping.

suite page suivante

Commande	Rôle et options
`ip dhcp snooping vlan 1`	L'applique au VLAN 1 (celui des postes).
`no ip dhcp snooping information option`	Désactive l'option 82 (inutile sans relais DHCP).
`ip dhcp snooping trust`	Déclare le port de confiance (celui du vrai serveur).
`ip dhcp snooping limit rate 10`	Plafonne le trafic DHCP à 10 paquets/s sur un port client.
Port-security (switch)	
`switchport mode access`	Force le port en mode accès (préalable à la port-security).
`switchport port-security`	Active la port-security sur le port.
`switchport port-security maximum 1`	Autorise une seule MAC sur le port.
`switchport port-security violation shutdown`	Coupe le port (`err-disabled`) en cas de violation.
`switchport port-security mac-address sticky`	Apprend et mémorise la MAC légitime automatiquement.
`show port-security`	Vue d'ensemble : MAC max, violations, action par port.
`show port-security interface fastEthernet0/3`	Détail d'un port : état, MAC source, compteur de violations.
`show interfaces fastEthernet0/3 status`	Affiche l'état du port (`err-disabled` après violation).
`shutdown` / `no shutdown`	Réactive manuellement un port tombé en `err-disabled`.